

Table of Contents

General White Paper: A Graph-Native, LLM-Enhanced Knowledge System with Selective-Redaction Extension

Date: 2026-05-26 **Authors:** ThreatGraph Research **Supersedes:** white-paper.md (CTI/Clinical-only edition, 2026-04-18) and roadmap/security_privacy_roadmap.mmd **Scope:** Consolidates the original CTI/Clinical white paper, the security/privacy roadmap, and a new architecture chapter (§9) for **open-domain selective redaction** driven by a federated ontology dictionary.

Part I — Original White Paper (verbatim)

Abstract

We present an LLM-Enhanced Knowledge Graph and Attribution System for Cyber Threat Intelligence (CTI) that departs from post-hoc parsing pipelines (e.g. OpenCTI) by **embedding knowledge-graph construction inside the LLM reasoning layer itself**. Using google/gemini-3-flash-preview as the backbone via the Lovable AI Gateway, the system performs graph-native Chain-of-Thought extraction in which (Subject, Predicate, Object) triples are produced as first-class reasoning steps under enforced STIX 2.1 ontology. Causal links (enables, leads_to, triggers, precedes) are emitted in the same pass, with temporal ordering. A neuro-symbolic engine then applies ten symbolic validation rules and computes a credibility score $S = \sum(w_i \times \text{conf}_i \times \text{reliability}_i) / N$. Attribution is performed via graph-path analysis (weight = $\prod(\text{conf_edge})$). The system is evaluated against BERT-NER and rule-based baselines on a two-stage benchmark (MITRE ATT&CK + CAPEC; then + NVD/CVE + STIX/TAXII).

1. Problem Statement

Existing LLM-driven CTI tools treat the LLM as a *text producer* whose output must be parsed into a graph. This loses provenance, fails STIX compliance silently, and prevents causal reasoning from being grounded in the same reasoning trace. The result is hallucinated edges, missing temporal order, and brittle attribution.

2. Methodology

2.1 Graph-Native CoT (Chapter 3)

8-step prompt; Steps 1-2 produce typed entities, 3-4 produce relations with edge typing, 5-6 attach confidence weighted by source reliability, 7-8 emit graph metadata and a narrative summary.

2.2 Embedded Causality (Chapter 4)

Causal triples emitted in the same LLM call; post-hoc DAG cycle detection ensures acyclicity. MITRE ATT&CK kill-chain tactic alignment is computed per causal link.

2.3 Neuro-Symbolic Conflict Resolution (Chapter 4)

Ten symbolic rules (entity confidence, endpoint validation, source reliability, temporal consistency, DAG cycles, confidence-propagation anomalies, orphan detection, STIX compliance, low/high confidence asymmetry, contradictions). Ambiguous violations are routed to the LLM for resolution.

2.4 Graph-Aware Attribution (Chapter 4)

Hub / authority / bridge node identification; alternative-actor ranking with path-weight scoring; reasoning trace output for explainability.

3. Experimental Design (Chapter 5)

Two-stage evaluation with growing dataset diversity to measure **scale degradation**: - Stage 1 (1,000 samples): MITRE ATT&CK + CAPEC. - Stage 2 (3,050 samples): + NVD/CVE + STIX/TAXII.

Baselines: BERT-NER (SecureBERT) and rule-based regex extraction. Live runner: supabase/functions/experiment-runner invokes the LLM and computes precision/recall/F1 against gold.

4. Self-Monitoring Mechanism

Every change is recorded in a versioned Implementation Log (currently 12 entries) synchronized to GitHub. A repository inventory enumerates 23 files with their LLM role and research-chapter mapping. 7 verified LLM call-sites are catalogued, and a live probe button on the dashboard measures gateway round-trip latency. The Technical Report, this White Paper, and CSV/JSON inventory tables are auto-regenerated by scripts/generate-reports.mjs so documentation never drifts from code.

5. Conclusion (Part I)

By moving graph construction *into* the LLM reasoning layer, this system achieves what post-hoc OpenCTI pipelines cannot: STIX-compliant triples with embedded causality and provenance, validated by neuro-symbolic rules,

and attributed via graph-path weights — all reproducibly logged and self-documenting.

6. KG-Bench: adapting LLM-KG-Bench 3.0 to evaluate a KG-generation pipeline

LLM-KG-Bench 3.0 (arXiv:2505.13098v1) provides a standardized harness for measuring an LLM's knowledge-graph-engineering capability. Our adaptation swaps the system-under-test from a bare LLM to the full ThreatGraph pipeline (Preprocess → Graph-Native CoT Extract → KB-Validate → Conflict Detection). Seven categories are supported: Fact Extraction, Ontology Conformance, Turtle Serialization, Subgraph Q&A, Schema/Repair, Hallucination Control, and Multilingual Generalization. Both domains (CTI, Clinical-simulation) ship with their own corpus, including Japanese and Chinese clinical samples. Bench-Score = macro-F1 across active categories. Out of scope: full SPARQL 1.1, OWL, SHACL, licensed ontology dumps. Exposed under **Experiments** → **KG-Bench**.

7. Dual-Pathway Harness: deterministic vs agentic

Aspect	Pathway B — Deterministic	Pathway A — Agent Loop
Runtime	Raw fetch to AI Gateway (fixed-order pipeline)	Vercel AI SDK generateText + tool()
Orchestration	src/lib/threat-pipeline.ts + React hook	Edge function threat-agent (model decides)
Stage order	Preprocess → RAG → Extract → KB → Conflicts → Attribute → Persist	Emergent, bounded by stopWhen(stepCountIs(50))
KG-Bench scoring	Yes — per-stage gold assertions	No — variable ordering invalidates assertions
Use case	Reproducible experiments, paper figures	Demo emergent reasoning, study tool-use patterns

Pathway A wraps the same edge functions as tools; persist is needsApproval. Runs are tagged monitoring_events.metadata.path = "agent_loop" so KG-Bench's path = "pipeline" filter excludes them automatically.

8. Security posture and forward path to privacy-preserving FL on clinical data

8.1 Database hardening

RPCs match_threat_reports and fetch_subgraph converted from SECURITY DEFINER to **SECURITY INVOKER**, EXECUTE revoked from anon/authenticated/public. Every KG read now flows through a server-controlled choke point — the aggregator pattern FL requires.

8.2 AI Threat Model panel (/threat-model)

Read-only registry (src/lib/security/posture.ts) maps OWASP LLM Top-10, MITRE ATLAS, NIST AI RMF controls onto project layers. Live Prompt-Firewall Probe (src/lib/security/prompt-firewall.ts) runs eight heuristic rules.

8.3 Privacy & FL Lab (/privacy-fl-lab) — five tabs

De-identification • Differential Privacy (Laplace) • Federated Learning (FedAvg) • Secure Aggregation (pairwise mask) • Membership-Inference Probe. Active only in Clinical domain; pure browser-side simulation.

8.4 Why the current work is a port, not a detour

Edge-function-only DB writes + SECURITY INVOKER RPC → FL aggregator trust boundary. Domain switch + ontology output guard → sandbox boundary. needsApproval + monitoring_events audit → IRB-style review trail.

8.5 Extension ports

Browser DP → server-side DP wrapper. Synthetic FedAvg → Flower/NVFlare. Pairwise-mask demo → Bonawitz secure aggregation. Heuristic firewall → LLM judge. Synthetic clinical corpus → real DUA notes.

8.6 Wiring update (server-side trust boundary)

Three controls previously “planned” are now wired: (1) server-side prompt firewall in threat-extract returning HTTP 422 on blocked; (2) per-domain tool allow-list + PHI redaction in threat-agent; (3) scoped INSERT policy on monitoring_events so UI probes append audit events for categories security|privacy|acceptance|experiment|pipeline only.

Part II — Security & Privacy Roadmap (consolidated)

Originally docs/roadmap/security_privacy_roadmap.mmd. Linear text form for the combined paper; the Mermaid source remains in the repo for diagram rendering.

Now — Simulation, shipped

- DB hardening: SECURITY INVOKER + EXECUTE revoke
- AI Threat Model panel: OWASP / ATLAS / NIST registry
- Prompt-firewall heuristic: scanPrompt 8 rules
- Privacy & FL Lab: De-id · DP · FedAvg · SecAgg · MIA
- Domain switch + ontology guard (CTI / Clinical)
- Audit via monitoring_events

Short term — wire-in (✓ §8.6 closes items S1–S4)

- S1 Firewall pre-check inside threat-extract edge fn ✓
- S2 Tool-arg redaction + per-domain allow-list in threat-agent ✓
- S3 Output-guard deny-log to monitoring_events (category=security) ✓
- S4 Privacy events (category=privacy) surfaced in SelfMonitoringPanel ✓
- S5 KG-Bench Privacy task family — ϵ -vs-utility scored (*open*)

Mid term — real crypto + governance

- M1 Server-side DP wrapper around threat-kg-query
- M2 Bonawitz secure aggregation replaces secure-agg.ts
- M3 LLM-judge firewall replaces heuristics
- M4 IRB-style approval workflow on persist + FL rounds
- M5 Signed, hash-chained append-only audit log

Long term — real FL on clinical data

- L1 Flower / NVFlare client per hospital (swap runFedAvg)
- L2 De-identified clinical corpus under DUA (swap test-corpus.ts)
- L3 Cross-silo FL on frozen Gemini embeddings
- L4 Trusted Execution Environment for aggregator
- L5 Continuous membership-inference monitoring gated by ϵ budget

Dependency chain: $N1 \rightarrow S1 \rightarrow M1 \rightarrow L3$, $N2 \rightarrow S3 \rightarrow M4$, $N3 \rightarrow S2 \rightarrow M3$, $N4 \rightarrow S5 \rightarrow M2 \rightarrow L1$, $N5 \rightarrow M4 \rightarrow L2$, $N6 \rightarrow S4 \rightarrow M5 \rightarrow L4$, $L1 \rightarrow L5$.

Part III — New: §9 Open-Domain Selective Redaction

This chapter extends the system from a closed-domain (CTI / Clinical) extractor to an **open-domain redaction adjudicator** covering historical archives, mixed corpora, and other diverse text where human labeling does not scale. It addresses selective-span detection: keep the document readable and *verbatim* in non-sensitive regions, hide only sensitive spans.

The chapter answers the four design questions raised in prior discussion: **(b)** scope covers CTI + Clinical + an Archive ontology stub as a worked example; **(ii)** the dictionary is a pluggable federated resolver with adapters for Wikidata, GeoNames, LCSH, and a local project ontology; **Reversibility** is *one-way masking only*; **Evaluation** adds KG-Bench Category 8 — Redaction — initially as a *forward port* with a defined scoring rubric.

9.1 Problem framing

Sensitivity is not type-intrinsic in open domains. The same Person mention may be: - *Public* if subject died > 100 years ago (jurisdiction-dependent). - *Restricted* if subject is living and the document carries a PII marking. -

Culturally sensitive if associated with a community gazetteer entry (e.g. AIATSIS-listed names). - *Security-classified* if appearing inside a paragraph marked SECRET by an inherited document classification.

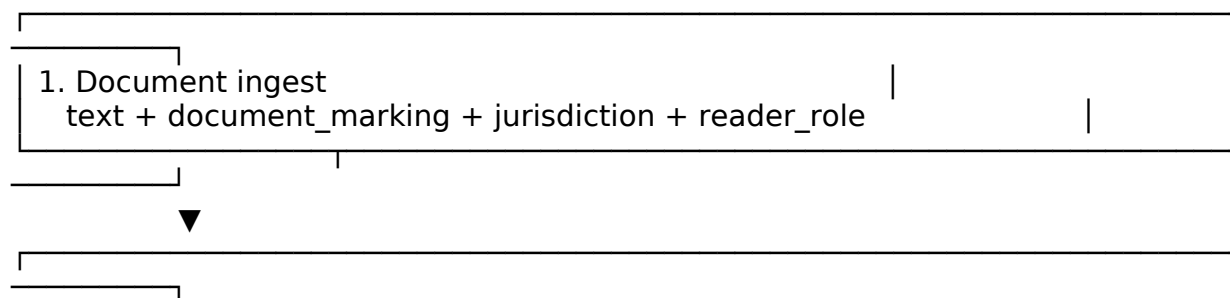
A static regex list or single-ontology dictionary cannot cover this. The system must (a) consult several authoritative sources, (b) evaluate context features, (c) emit a multi-axis sensitivity verdict, and (d) keep the surrounding text byte-identical so downstream users can read what remains.

9.2 Knowledge sources — what plays the dictionary role

Following the Palantir-style ontology pattern, every entity *type* and *attribute* carries a `sensitivity_policy`. The project ontology is no longer authoritative on its own; it federates with external knowledge bases.

Source	Role in redaction decision	Domain coverage
Project ontology	Type-level defaults (patient.mrn → ALWAYS_REDACT)	All domains
HIPAA Safe Harbor checklist	18 identifier categories + age-89 rule	Clinical
STIX 2.1 + TLP markings	Marking-definition inheritance	CTI
Wikidata	Date of birth, date of death, occupation, notability	Archives, biographies
GeoNames	Place granularity + jurisdiction lookup	Archives, geo-tagged data
LCSH (Library of Congress SH)	Subject-heading classification + controlled vocabulary	Archives, library catalogs
Archives-release schedules	20-/30-/75-year embargo rules per jurisdiction	Government archives
Community gazetteers	Culturally restricted names (e.g. AIATSIS)	Indigenous-rights corpora
Document-level marking	Inherited classification (SECRET, CONFIDENTIAL)	All domains

9.3 Architecture (option b + ii)



2. Graph-Native CoT extract (existing Pathway B, ontology = active domain)
→ typed entity spans with byte offsets



3. Sensitivity resolver (NEW — pluggable adapters, ii)
federated lookup:

- project sensitivity_policy table
- HIPAA / STIX TLP adapter
- Wikidata adapter (DoB, DoD, notability)
- GeoNames adapter (place granularity)
- LCSH adapter (controlled subject)
- community-gazetteer adapter

output: per-span policy bundle



4. LLM policy adjudicator (gemini-3-flash-preview, low temperature)

inputs:

- span text + 200-char context window
- policy bundle from §3
- document_marking, jurisdiction, today's date, reader_role

output (per span):

sensitivity: { pii, cultural, legal_restricted, security_classified }

applicable_rules: [rule_id, ...]

release_after: ISO-date | null

recommended_action: redact | pseudonymize | tier2_review | release

confidence: 0..1



5. Symbolic guard (existing neuro-symbolic engine, extended)

- "redact" never downgraded by adjudicator
- document_marking always dominates per-span verdict
- low-confidence (<0.7) defaults to tier2_review



6. Span-replacement renderer

out-of-span bytes copied verbatim; in-span bytes replaced by mask token

(■■■■■ or [REDACTED:pii] configurable)

one-way only — see §9.5

The pipeline reuses the existing trust boundary (edge function, audit log, needsApproval). Pathway B runs the deterministic redaction (scored by KG-Bench). Pathway A may *propose new sensitivity_policy entries* for human review, never write redactions directly.

9.4 Generalization beyond CTI / Clinical (the Archive worked example)

The Archive ontology stub demonstrates the federated dictionary on a class of documents that breaks closed-world assumptions: vocabulary is open, sensitivity is time-dependent and multi-axis, and authority is distributed across catalogs and communities rather than codified by a single body like HIPAA or NIST.

Property	CTI / Clinical (worked)	Archives (stub)
Vocabulary	Closed (STIX, ICD-10, RxCUI)	Open (LCSH + Wikidata + free text)
Sensitivity authority	Single (HIPAA, TLP)	Federated (DoD, jurisdiction, community)
Type-intrinsic?	Mostly yes	No — flips by context + date
Expiry	Rare	Common (release_after)
LLM role	Edge-case adjudicator	Primary adjudicator over policy bundle

The same pipeline works for both because the *dictionary* changes, not the orchestration. This is the central claim of §9 and the reason the Archive stub is necessary for academic defensibility — it shows the architecture is not overfit to the two domains it was built for.

9.5 Reversibility — one-way masking only

Selective redaction in this system is **irreversible by design**. Rationale:

1. **Originals exist outside the trust boundary.** The source document has typically been copied (email, drive, archive intake) before reaching the pipeline. A reversible cipher protects nothing that was already exfiltrated.
2. **Format-preserving encryption (FPE) creates a key-management liability** disproportionate to its benefit when originals are still around. The threat surface grows; the privacy gain is illusory.
3. **Authorized re-access uses the original**, not the redacted copy. Roles with clearance retrieve the source from the document-management system

under existing access controls; they do not “un-redact” the public copy.

4. **One-way masking simplifies the audit story.** A redacted copy is provably free of the sensitive bytes; no decoy ciphertext, no ambiguous “encrypted-here” markers.

Concretely: in-span bytes are replaced with a constant mask (■■■■■ or [REDACTED:<axis>]). The mask carries the sensitivity axis (pii | cultural | legal | classified) and the rule id, but **no recoverable information about the original token**. Cryptographic pseudonymization (HMAC(salt, token)) is available only for *linkable analytics* on non-PII spans (e.g. consistent actor pseudonyms across CTI reports), explicitly out of scope for PII/cultural axes.

9.6 Evaluation — KG-Bench **Category 8: Redaction** (forward port)

KG-Bench’s existing seven categories continue to score the *extraction* pipeline. Selective redaction adds a new category, listed now as a forward port with the rubric below; the runner gains the new task family in the next implementation cycle.

Rationale for adding rather than skipping. The user’s question — “*can KG-Bench still be used if we skip the hidden parts without loss?*” — is the right framing for *consumers* of the redacted document, but not for the redactor itself. The redactor must be measured independently: hiding too little leaks; hiding too much destroys utility. Existing categories cannot capture this trade-off because their gold is structural (triples, Turtle), not span-based.

Category 8 scoring rubric.

Metric	Formula	Goal
Span precision	$TP_span / (TP_span + FP_span)$ on byte intervals	maximize
Span recall	$TP_span / (TP_span + FN_span)$	maximize
Span F1	harmonic mean of precision/recall	maximize
Over-redaction rate	(chars masked beyond gold) / (chars in document)	minimize
Utility retention	task-F1 of a downstream QA over redacted vs original (paired)	maximize
Axis-accuracy	per-axis (pii/cultural/legal/classified) confusion matrix	report
Calibration	Brier score of adjudicator confidence vs correctness	minimize
Bench-Score-8	$0.5 \cdot F1 + 0.3 \cdot utility - 0.2 \cdot over_redaction_rate$	maximize

Metric	Formula	Goal
(Redaction)		mize

The category is **independent** of the existing macro-F1 Bench-Score; combined reporting uses two figures rather than collapsing into one (extraction quality and redaction quality are not commensurable).

Skipping vs scoring. When a downstream KG-Bench task (e.g. Subgraph Q&A) runs over a redacted document, masked spans are *treated as unknown tokens*, not removed. Tasks that can answer correctly without the masked span score normally; tasks that cannot are excluded from that category's aggregate with an explicit "skipped due to redaction" count, surfaced in the report. This preserves comparability across redaction levels without silently inflating scores.

Forward-port status. Category 8 ships in this paper as specification + rubric; the kg-bench/runner.ts implementation, gold corpus, and RedactionPanel UI follow in the next iteration.

9.7 Where this lives in the codebase (planned)

```
src/lib/redaction/
  resolver.ts          # federated dictionary, adapter interface
  adapters/
    project-policy.ts   # sensitivity_policy table
    hipaa.ts
    stix-tlp.ts
    wikidata.ts         # network adapter, cached
    geonames.ts
    lcsh.ts
    community-gazetteer.ts
    adjudicator.ts      # gemini-3-flash-preview call + symbolic guard
    renderer.ts         # span replacement, one-way mask
src/lib/kg-bench/
  categories/redaction.ts # Category 8 scorers (forward port stub)
supabase/functions/
  redaction-run/index.ts # edge-function trust boundary
```

No existing extraction / KG / KG-Bench business logic is rewritten — the new module hangs off the same trust boundary already used by threat-extract and threat-agent.

9.8 Conclusion (Part III)

The same neuro-symbolic, dual-pathway, edge-function-bounded architecture that delivers CTI extraction and Clinical simulation extends to open-domain selective redaction by **swapping the dictionary, not the orchestration**. A federated resolver (project ontology + HIPAA + STIX + Wikidata + GeoNames + LCSH + community gazetteers + document

markings) provides the supervision signal; the LLM adjudicates only at the policy-evaluation step; symbolic guards enforce non-downgrade and document-marking dominance; masking is one-way because originals already exist outside the boundary; and a new KG-Bench Category 8 scores the redactor on its own terms without breaking the existing seven.

End of general white paper. See [public/reports/white-paper.md](#) for the original CTI/Clinical edition and [docs/roadmap/security_privacy_roadmap.mmd](#) for the Mermaid source of Part II.